

## Solución al lab **SigninBleed** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/SigninBleed
Session Actions Edit View Help

W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde signinbleed.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: SigninBleed
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de Root (formato SigninBleed{...}):
```

Iniciaremos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/SigninBleed
Session Actions Edit View Help

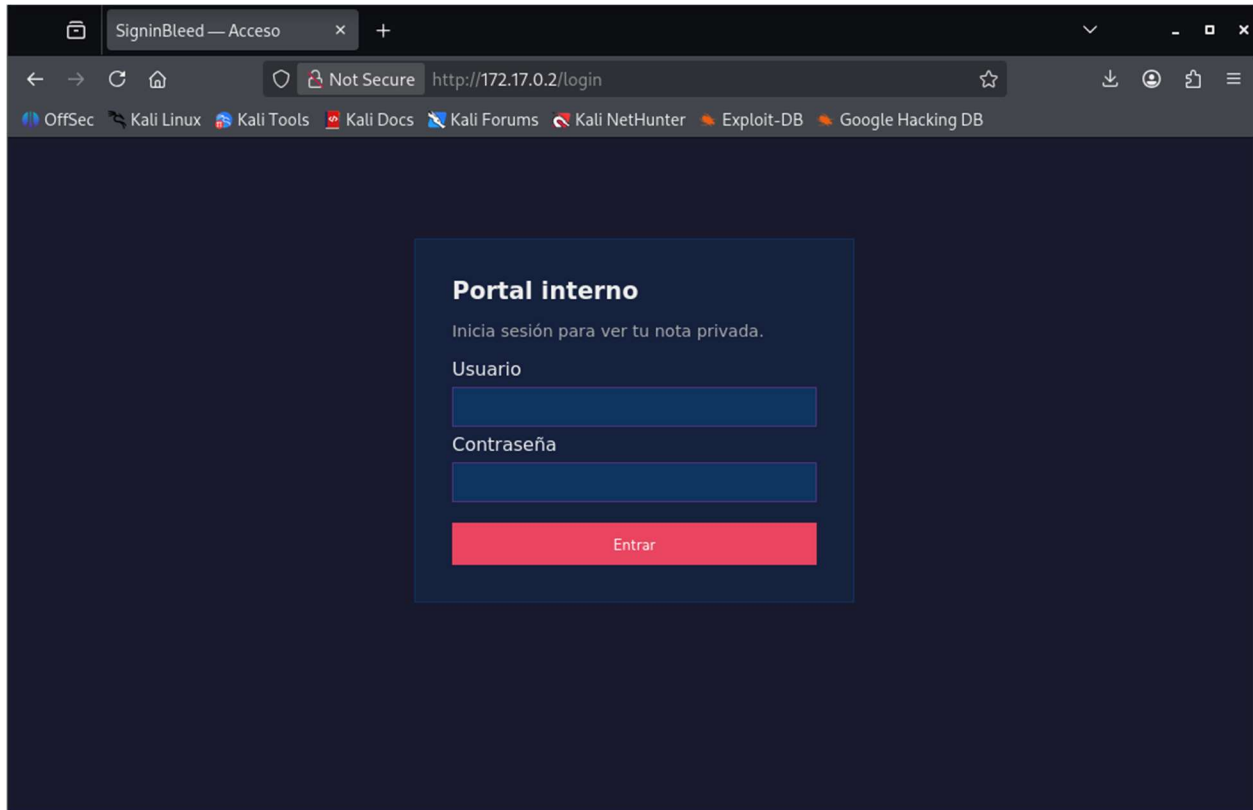
chifay@kali: ~/Whoami-Labs/SigninBleed
chifay@kali: ~/Whoami-Labs/SigninBleed

(chifay@kali)-[~/Whoami-Labs/SigninBleed]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_signinbleed
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-01 09:11 -0600

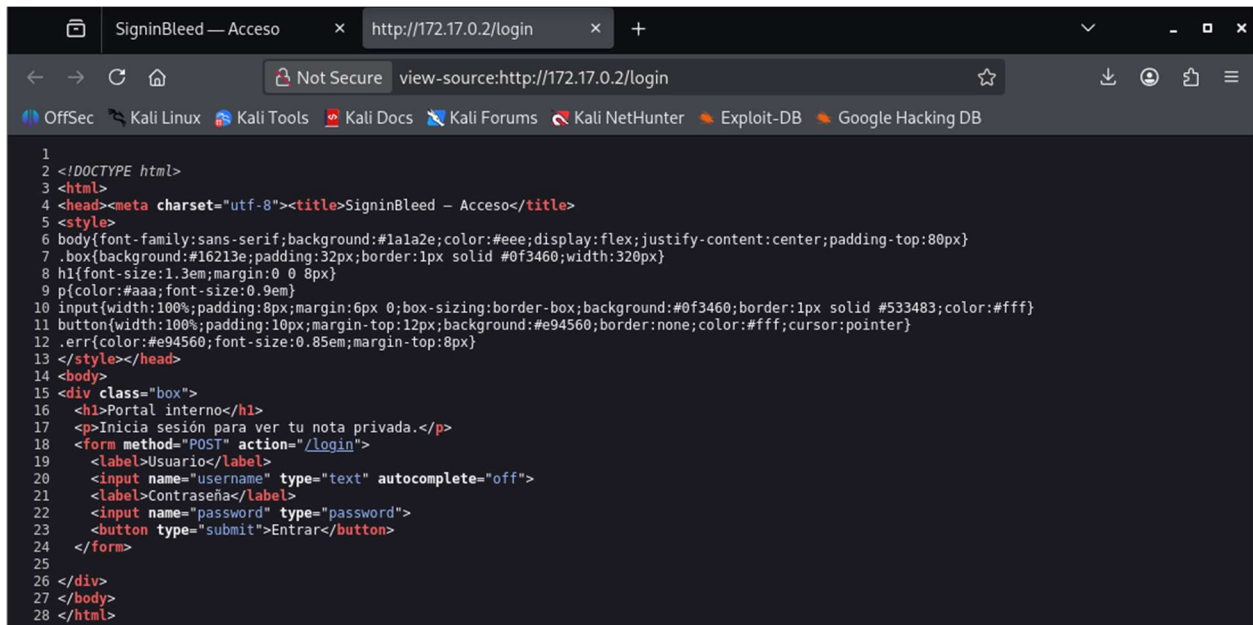
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http      syn-ack ttl 64  Unicorn
|_ http-title: SigninBleed \xE2\x80\x94 Acceso
|_ Requested resource was /login
|_ http-server-header: unicorn
|_ http-methods:
|_ Supported Methods: GET OPTIONS HEAD
MAC Address: 1E:A1:22:D0:D7:48 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Ya que no tenemos credenciales para ssh comenzaremos analizando el servicio web

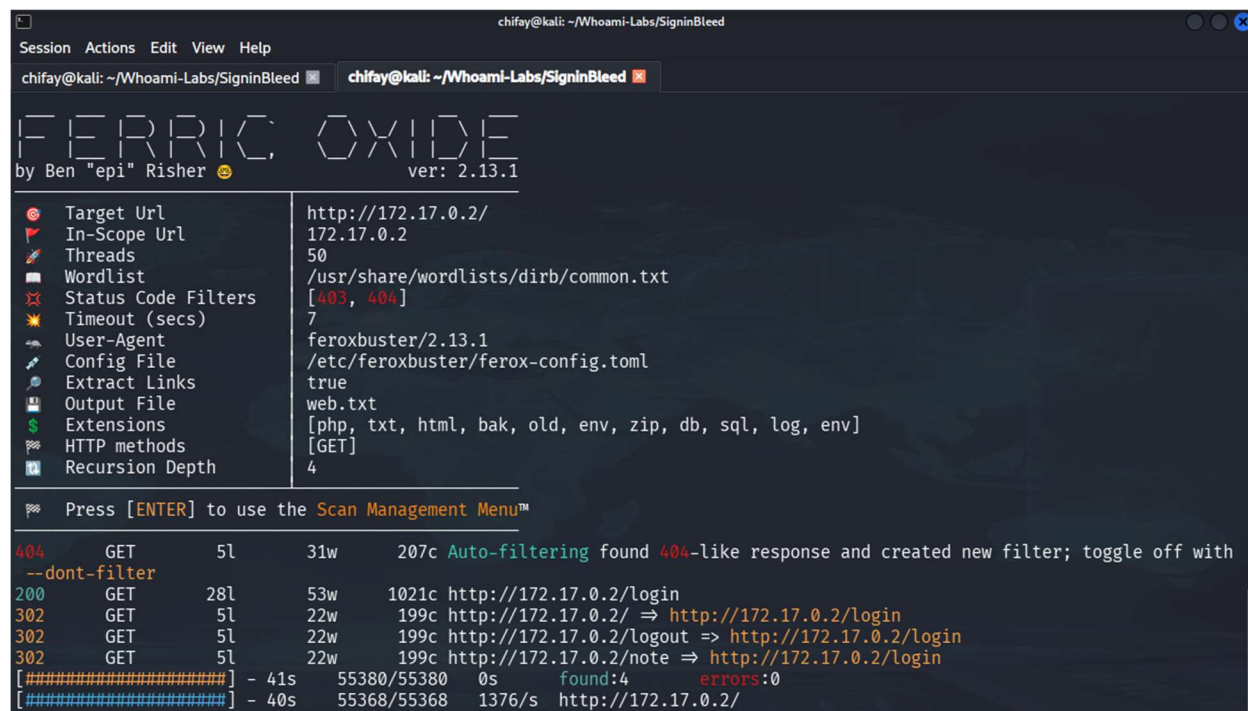
## Inspección visual



## Código fuente



## Enumeración de directorios con feroxbuster



```
chifay@kali: ~/Whoami-Labs/SigninBleed
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/SigninBleed chifay@kali: ~/Whoami-Labs/SigninBleed

FERROX OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 28l 53w 1021c http://172.17.0.2/login
302 GET 5l 22w 199c http://172.17.0.2/ => http://172.17.0.2/login
302 GET 5l 22w 199c http://172.17.0.2/logout => http://172.17.0.2/login
302 GET 5l 22w 199c http://172.17.0.2/note => http://172.17.0.2/login
[#####] - 41s 55380/55380 0s found:4 errors:0
[#####] - 40s 55368/55368 1376/s http://172.17.0.2/
```

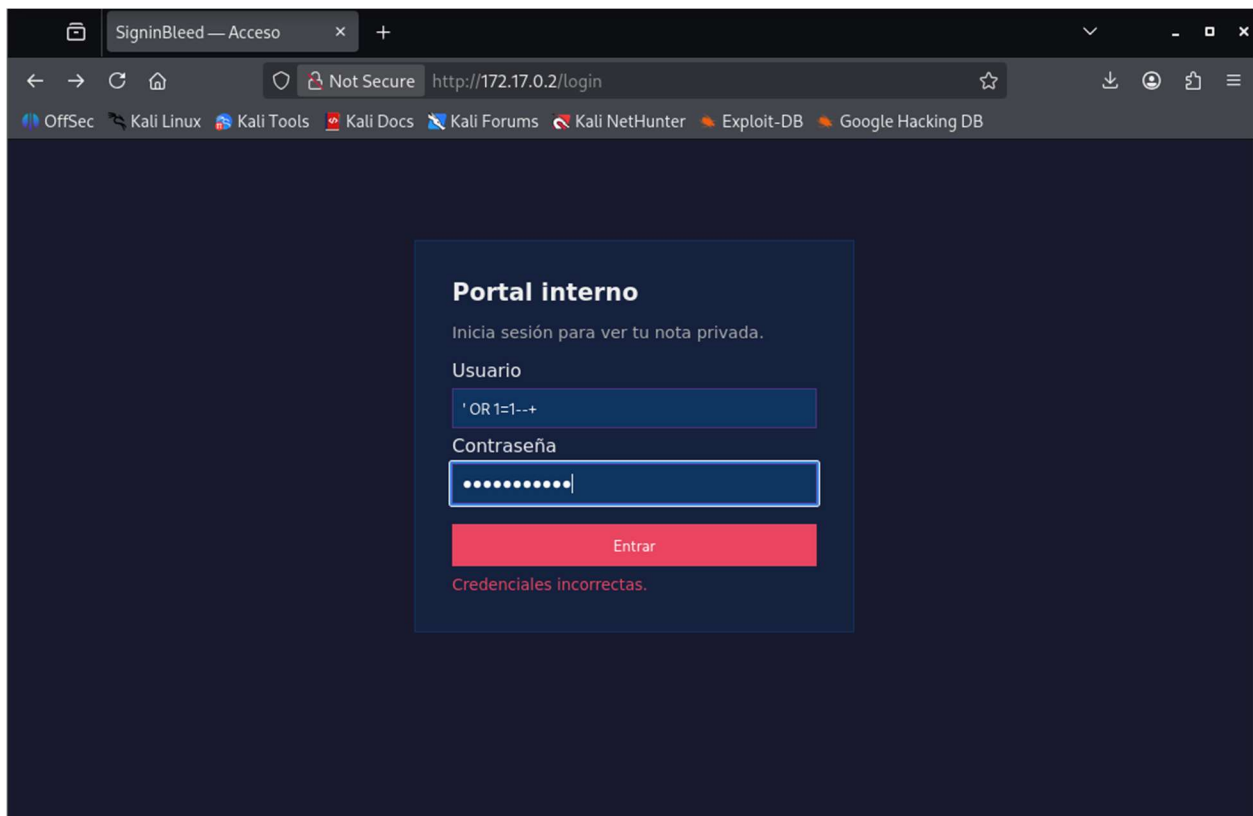
El nombre "SigninBleed" sugiere una vulnerabilidad de **filtración de credenciales** o **bleeding de información** en el proceso de autenticación

### Posibles vulnerabilidades:

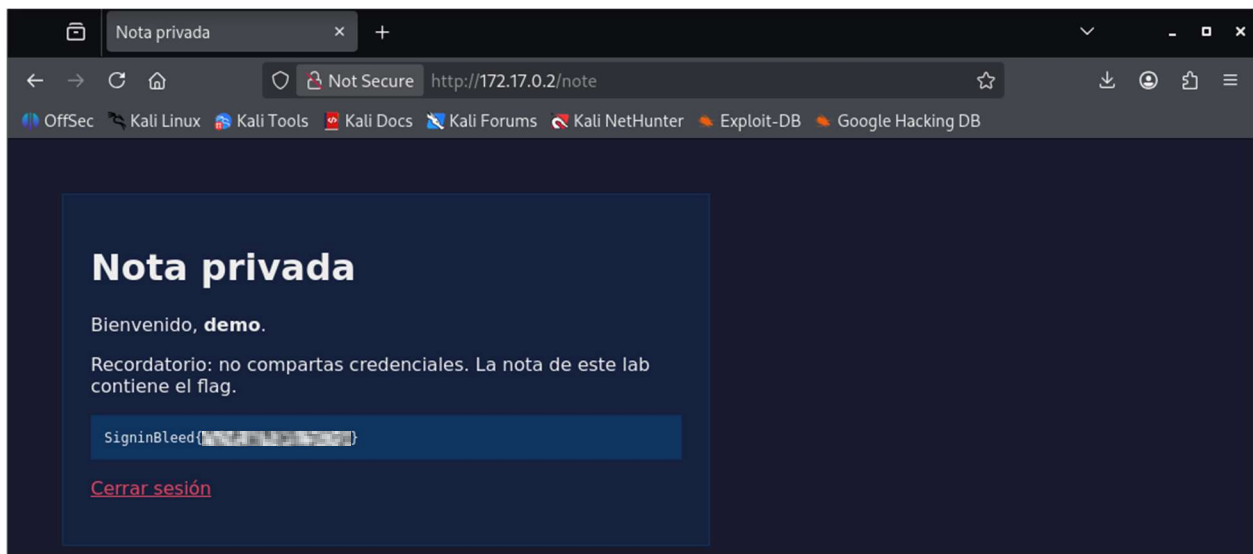
1. **Timing Attack** → El servidor tarda más tiempo en responder si el usuario existe
2. **User Enumeration** → El servidor revela si un usuario existe o no
3. **SQL Injection** → Vulnerabilidad en la consulta de login
4. **Information Disclosure** → La respuesta de error revela información

Timing Attack no dio el mismo tiempo para todos los usuarios que probamos

SQL Injection



Con este payload pudimos bypasear el login y nos redirige el panel de /note



Ahí nos revela el valor de la bandera, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/SigninBleed
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/SigninBleed

[*] Cargando imagen desde signinbleed.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: SigninBleed
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de Root (formato SigninBleed{...}): SigninBleed{[REDACTED]}
;Felicitaciones! Has comprometido SigninBleed.

TIEMPO TOTAL: 00h 47m 14s
FECHA Y HORA: 2026-09-01 09:56:34 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```